

General security concepts (12%)

1.1 Security Control Categories

- **Technical** – Controls implemented via systems (firewalls, AV, OS controls)
- **Managerial** – Administrative controls: security policies, SOPs
- **Operational** – Controls carried out by people: security guards, awareness programs
- **Physical** – Limits physical access: fences, locks, badge readers, guard shacks

1.1 Control Types

- **Preventive** – Blocks an action before it happens (firewall rules, door locks)
- **Deterrent** – Discourages an attempt but does *not* directly prevent it (warning signs, splash screens)
- **Detective** – Identifies & logs an intrusion attempt; may not prevent access (system logs, motion detectors)
- **Corrective** – Applied after an event to reverse impact and restore operations; goal is to **continue operating with minimal downtime** (backups, policies)
- **Compensating** – Used when **existing controls aren't sufficient**; often temporary — prevents exploitation of a weakness until a proper fix is in place (power generator, separation of duties, blocking an app via firewall instead of patching it)
- **Directive** – Directs behavior toward compliance; relatively

weak ("Authorized Personnel Only" signs, compliance policies)

1.2 CIA Triad

- **Confidentiality** – Prevent unauthorized disclosure of information
- **Integrity** – Ensure data is stored and transferred as intended; any modification is **detectable** (hashing, digital signatures, certificates, non-repudiation)
- **Availability** – Systems and data remain accessible to authorized users (redundancy, fault tolerance, patching)
- **Non-repudiation** – Proof that a message came from a specific sender and was not altered. Achieved by *signing with a private key* and verifying with a public key

1.2 Gap Analysis

- **Gap analysis** – Comparing your current security posture to a desired baseline to identify weaknesses. Can take weeks or months.
- **Baseline** – The target security standard (e.g. NIST SP 800-171, ISO/IEC 27001)

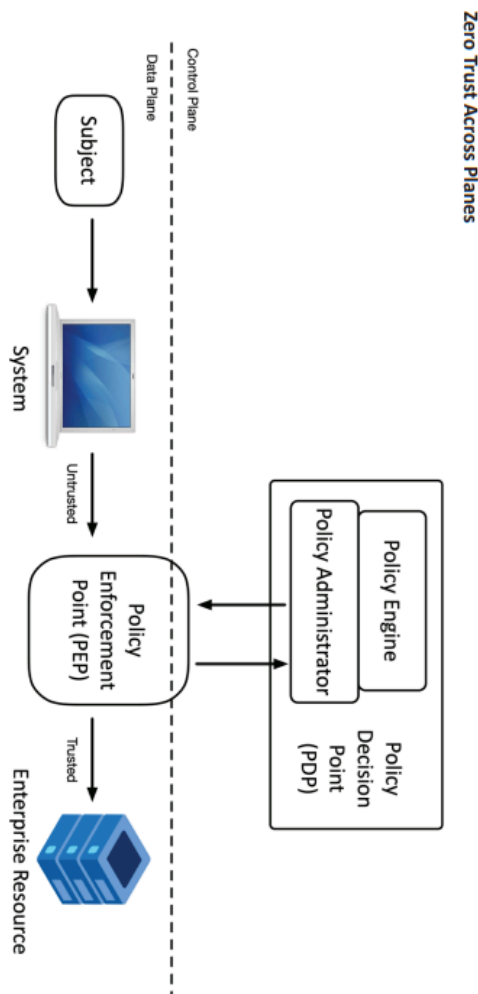
1.2 AAA Framework

- **Identification** – Who you claim to be
- **Authentication** – Prove who you are **Authentication People:** digital signatures;
Authentication Systems: digitally signed certificates validated by a CA
- **Authorization** – What resources you can access after authentication. Uses an **Authorization model** (e.g. **RBAC** – Role-Based Access Control) to abstract user → resource relationships and scale cleanly
- **Accounting** – Logs all resource usage: login time, data sent/received, logout time

1.2 Zero Trust

- **Zero Trust** – Nothing is inherently trusted; every access request must be verified regardless of location
- **Control Plane** – Makes and communicates access decisions:
 - **Policy decision point(PDP):** Encompasses policy engine + administrator

- Process: evaluate people & processes → compare existing systems → identify gaps → produce a formal report with recommendations
- Evaluating people includes: formal experience, current training, knowledge of security policies & procedures



- **Policy Engine** – Grants, denies, or revokes access
- **Policy Administrator** – Generates access tokens/credentials; tells the PEP to allow or disallow access
- **Adaptive Identity** – Risk-based auth (e.g. unusual login location = more verification required)
- **Threat Scope Reduction** – Limit the number of possible entry points
- **Policy-Driven Access Control** – Combines rules + adaptive identity
- **Data Plane** – Where traffic actually flows:
 - **Subject/System** – The user or device making the request
 - **Policy Enforcement Point (PEP)** – The gatekeeper; allows, monitors, or terminates connections based on Control Plane decisions
- **Security Zones** – Trusted vs. untrusted, internal vs. external; zone membership alone can allow or deny traffic

1.2 Physical Security

1.2 Deception & Disruption Technology

- **Bollards** – Concrete posts blocking vehicles while allowing pedestrians
- **Access Control Vestibule** – Mantrap; only one door open at a time, controlling one-at-a-time entry
- **Fencing** – Perimeter barrier; can be transparent/opaque, robust, or topped with razor wire
- **Video Surveillance (CCTV)** – Motion recognition, object/face detection, networked & recorded
- **Security Guard** – Physical protection; two-person integrity minimizes single-person attack exposure
- **Access Badge** – Photo ID worn at all times; electronically logged
- **Lighting** – More light = fewer blind spots; important for facial recognition
- **Sensors:**
 - *Infrared* – Detects motion in light and dark
 - *Pressure* – Floor/window sensors detect force changes
 - *Microwave* – Detects movement across large areas
 - *Ultrasonic* – Reflected sound waves for motion/collision detection
- **Honeypot** – Fake device/environment to lure attackers and observe their techniques
- **Honeynet** – A full fake network of honeypots providing multiple data sources
- **Honeyfile** – Fake file (e.g. passwords.txt) placed as bait; alert fires on access
- **Honeytoken** – Fake traceable data (API credentials, email addresses, DB records, cookies) embedded in the honeynet; notifications sent when used

Together these create a fake environment to log exactly what attackers do and how they move through a system.

1.3 Change Management

- **Approval Process** – Formal request documenting purpose, scope, schedule, affected systems, risk, and change control board sign-off
- **Ownership** – The owning dept. manages the process but typically does *not* perform the actual change (IT does)
- **Stakeholders** – All parties impacted by the change, which may be broader than expected
- **Impact Analysis** – Risk assessment (high/medium/low) of what breaks if the change is made — **or not made** (e.g. unpatched vulnerability, application unavailability, unexpected downtime)
- **Test Results** – Sandbox testing in an isolated environment before production deployment
- **Back-out Plan** – Pre-prepared rollback to restore the previous state if the change fails
- **Maintenance Window** – Scheduled low-impact time (usually overnight) communicated to all affected parties
- **Standard Operating Procedure** – Change management policy

1.3 Technical Change Management

- **Allow List** – Only approved applications can run; very restrictive
- **Deny List** – Blocks known-bad applications (AV, anti-malware); everything else allowed
- **Restricted Activities** – Change approval is specific; scope cannot expand without further approval
- **Downtime** – Communicate duration to affected users; automate failover to secondary systems if possible
- **Service Restart** – Restart only the affected service/daemon without rebooting the full system
- **Application Restart** – Full application close and relaunch when a service restart isn't enough
- **Legacy Applications** – Unsupported, undocumented apps; document thoroughly before making any changes
- **Dependencies** – Service A may require Service B; changes must account for cascading restart needs
- **Documentation** – Update network diagrams and

must be documented, living, and accessible to the org

policies/procedures after every change

- **Version Control** – Track config changes over time; allows rollback to prior settings

1.4 Public Key Infrastructure (PKI)

- **PKI** – Policies, hardware, software, and procedures to create, distribute, manage, store, and revoke digital certificates. All about *trust*.
- **Public Key** – Freely shared; used to encrypt data or verify signatures
- **Private Key** – Kept secret by owner; used to decrypt data or create signatures. Cannot be derived from the public key.
- **Symmetric Encryption** – Single shared key encrypts & decrypts. Fast but hard to distribute securely.
- **Asymmetric Encryption** – Public/private key pair. Data encrypted with the public key can only be decrypted with the private key. Slower but solves key distribution.
- **Key Escrow** – A trusted third party holds copies of private keys (e.g. for legal/business access). Controversial but sometimes required.

1.4 Encrypting Data & Key Management

- **Data at Rest** – Full-disk encryption (BitLocker, FileVault), file encryption (EFS)
- **Database Encryption** – Transparent (whole DB with symmetric key) or record-level (per-column keys)
- **Transport Encryption** – HTTPS, VPNs (SSL/TLS client-based; IPsec site-to-site)
- **Encryption Algorithms** – AES (strong, current standard); DES (64-bit, outdated). Both sides must use the same algorithm.
- **Key Lengths** – Symmetric: 128-bit+; Asymmetric: 3,072-bit+. Larger = more secure, slower to brute-force.
- **Key Stretching** – Repeatedly hashing a weak key to make brute-force exponentially harder
- **Key Exchange** – Asymmetric encryption is used to securely deliver a symmetric session key in-band

- **TPM (Trusted Platform Module)**
– Chip on device motherboard; stores keys, random number gen, protects BitLocker keys
- **HSM (Hardware Security Module)** – Dedicated hardware for large-scale key storage & cryptographic acceleration
- **Key Management System** – Centralized software to create, rotate, associate, and log all keys across services
- **Secure Enclave** – Isolated hardware processor for secrets; own boot ROM, true RNG, AES encryption in hardware

1.4 Obfuscation

- **Obfuscation** – Making data unclear or hidden without necessarily removing it
- **Steganography** – Hiding a message inside another file (image, audio, video, TCP packets). The container is the *coverttext*. Security through obscurity.
- **Tokenization** – Replacing sensitive data with a random non-sensitive token. Common in **credit card processing** — a captured token cannot be reused by an attacker. Not encryption — no mathematical relationship between token and

1.4 Hashing & Digital Signatures

- **Hash** – One-way fixed-length fingerprint of data (message digest). Cannot reverse to recover original. Used for integrity checks and password storage.
- **Collision** – Two different inputs producing the same hash. Breaks integrity. MD5 has known collisions — do not use for security.
- **Practical Hashing** – Verify a downloaded file by comparing its hash against the publisher's posted hash value

original. No encryption overhead.

- **Data Masking** – Hiding portions of data from view (e.g. showing only last 4 digits of SSN). Data may remain intact in storage; visibility controlled by permissions.

1.4 Blockchain

- **Blockchain** – A *distributed* ledger replicated across all nodes in a network. Every transaction is logged and verified by the network. Tampering with a block invalidates all following hashes and is rejected. Used for payments, digital ID, supply chain, voting.

1.4 Certificates

- **Digital Certificate** – Binds a public key to an identity (X.509 format). Contains serial #, version, signature algorithm, issuer, holder name, public key, extensions.
- **Root of Trust** – An inherently trusted component (HSM, Secure Enclave, CA) that forms the foundation of the trust chain
- **Certificate Authority (CA)** – Trusted entity that digitally signs certificates. You trust the CA,

- **Salting** – Adding a unique random value to each password before hashing. Defeats **rainbow table attacks** (precomputed hash lookups). Salt is stored alongside the hash. Each user gets a different salt → same password produces a different hash.
- **Digital Signatures** – Sender hashes the message then encrypts the hash with their *private key*. Recipient decrypts with sender's *public key* and re-hashes to compare. Provides **integrity, authentication, and non-repudiation**.

1.4 Certificates (continued)

- **CSR (Certificate Signing Request)** – Generate a key pair, submit the public key + identifying info to a CA. CA validates, signs, and returns the certificate.
- **Wildcard Certificate** – Uses Subject Alternative Name (SAN); a single cert covers all subdomains of a domain (e.g. *.example.com)

therefore you trust what the CA signs.

- **Third-Party CA** – Built into browsers; purchase a cert and everyone trusts it automatically
- **Private CA** – Internal org CA; devices must be configured to trust it. Built with Windows Certificate Services or OpenCA.
- **Self-Signed Certificate** – Signed by your own internal CA; install your CA cert on all devices so they trust it
- **Key Revocation / CRL** – Certificate Revocation List maintained by the CA. Browsers check it to confirm a cert is still valid.
- **OCSP (Online Certificate Status Protocol)** – Real-time per-certificate revocation check via HTTP; more efficient than downloading the full CRL
- **OCSP Stapling** – The certificate holder pre-fetches their own OCSP status from the CA and "staples" it into the SSL/TLS handshake, reducing CA load and improving speed